MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 026 · AUGUST 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

BUYER'S GUIDE · CLOUD AND ESPS

GCC High or Not: The External Service Provider Decision

32 CFR 170.19 and DFARS 7012 pull your cloud and your MSP into assessment scope. What decides GCC High versus an enclave, and the matrix to demand first.

BY **MAXINE** READING TIME · 6 MIN ESP · CLOUD · FEDRAMP · CMMC · MSP

The most consequential purchase in a Level 2 program is not a tool. It is the decision about who else ends up inside your assessment boundary, and most small contractors make that decision twice without recognizing either instance as a decision at all. The first time is the productivity cloud: commercial Microsoft 365, GCC High, or an enclave built to hold exactly the population that touches CUI. The second is the managed service provider that keeps the lights on, which almost nobody files under compliance spending until an assessor asks who holds the keys.

FIELD COPY
ISSUE Nº 026
ESP

The rule that turns a vendor into a stakeholder

32 CFR 170.19 is the reason a vendor relationship is not a side conversation from your assessment. It defines the external service provider category and sets the rule plainly: an ESP that handles, processes, stores, or transmits your CUI either comes inside your assessment boundary, with its people, its systems, and its practices examined alongside your own, or it holds its own CMMC certification at the level your work requires. There is no third door where a vendor touches CUI and stays invisible to the C3PAO.

DFARS 252.204-7012(b)(2)(ii)(D) does the same work for the cloud specifically, and it does it in more exacting terms. A cloud service provider that stores, processes, or transmits covered defense information on a contractor's behalf must meet a security level equivalent to the FedRAMP Moderate baseline, at minimum. The clause does not stop at the baseline. It flows down the incident reporting timeline and the media preservation obligations that bind the prime contractor directly onto the cloud provider, which means a breach at your vendor is not the vendor's problem to manage quietly. It is yours to report on the same clock 7012 already put you on.

Read together, the two rules say the same thing from different directions: scope was never just the systems you own. It is every system and every person with a path to your CUI, purchased or not.

2

RULES THAT PULL A THIRD PARTY INTO YOUR ASSESSMENT - 32 CFR 170.19 AND DFARS 252.204-7012(B)(2)(II)(D)

Moderate

THE FEDRAMP BASELINE DFARS 7012 SETS FOR A CLOUD SERVICE THAT TOUCHES COVERED DEFENSE INFORMATION

1

CREDENTIAL - DOMAIN ADMIN OVER THE ENCLAVE - THAT PUTS AN MSP IN SCOPE WHETHER OR NOT IT EVER OPENS A CUI FILE

The cloud call is the easier of the two

Of the two decisions, the productivity cloud is the one contractors at least know they're making. Commercial Microsoft 365 is the cheapest seat on the market and, run alone, the one least likely to satisfy 7012(b)(2)(ii)(D) for CUI workloads - it was never built against the FedRAMP Moderate bar the clause sets. GCC High is Microsoft's answer built for that bar and for the export-control questions that come with defense work, and it carries a real per-seat premium over commercial licensing, charged against every seat in the tenant regardless of who in that tenant ever opens a CUI file. A CUI enclave built to hold only the people and systems that actually touch covered information, the kind priced against the whole network in Issue Nº 010, turns that math around: the build cost is fixed and one-time, and it scales with your CUI population instead of your headcount. This piece will not re-run that topology arithmetic - Issue Nº 010 already did, and the conclusion travels here unchanged: a boundary that scopes tightly is usually cheaper than one that scopes by default.

What belongs here instead is the claim to retire. GCC High is not required by regulation. It is one way, a well-marketed way, of meeting a FedRAMP-equivalent requirement that an enclave or another qualifying architecture can

◆ CHECK THE MARKETPLACE, NOT THE SLIDE

A vendor's own claim about its FedRAMP status is marketing copy. The FedRAMP Marketplace listing is the record - authorization type, sponsoring agency, and baseline are public and searchable before you sign anything.

also meet. A vendor who tells you GCC High is mandatory is selling you the shortcut to a sale, not describing the clause. Verify any product's actual authorization on the FedRAMP Marketplace before you take a sales deck's word for its baseline, and read how MacTech scopes an enclave as the comparison case, not the only alternative.

The MSP surprise: administrative access is its own category

The second decision is the one contractors miss, and it is not about data at all. Most small programs scope their MSP relationship by asking whether the technician ever opens a file that contains CUI. That is the wrong question. Under 32 CFR 170.19, a security protection asset - anything that provides a security function for the CUI boundary, including the identity and access management layer that controls it - is in scope on its own terms. Domain admin over your enclave is exactly that kind of asset. An MSP holding those credentials is inside your assessment the moment the access exists, whether its technicians have ever seen a CUI document or not.

This is the scoping conversation that gets skipped because it does not look like a data conversation. A program office can scope its file shares and its email flows with real discipline and still hand an outside vendor unrestricted administrative control over the systems that enforce every other control in the plan - the account that can create a user, reset a password, or disable logging is a more consequential asset than most of the documents it protects. If that vendor cannot produce its own certification at the level your CUI requires, the access itself has to be examined as part of your assessment, and a program that never asked the question finds out from the assessor instead of from its own SSP.

The artifact to demand before you sign

One document settles both decisions before they become a discovery made under an assessor's questions: the shared responsibility matrix, sometimes labeled a customer responsibility matrix. Every FedRAMP-aligned cloud provider and every serious MSP has one, and it is not a marketing attachment. It is a line-by-line map of the requirements you are both bound by, with each one assigned to the provider, to you, or to both.

Get it before you sign, not after. Read every line marked shared and ask, specifically, who executes it and on what schedule - a shared line with no named owner on your side is a control nobody performs. And treat every line marked customer responsibility as a task assigned to a person in your organization by name, because the failure that shows up in assessment after assessment is not exotic.

The matrix said customer responsibility. The customer assumed the vendor had it covered. Nobody did it for two years.

That gap does not surface in a quarterly review. It surfaces when a C3PAO asks for evidence of a control the contract always said was yours, and the honest answer is that everyone believed someone else was holding it. A shared responsibility matrix read closely before signature is cheap insurance against exactly that sentence. Read it after, and it is a finding with your name on it.

MacTech builds and operates CUI enclaves from inside the boundary it draws, monitoring included - the architecture behind that is Issue Nº 016's look at EnclaveWatch. If you are weighing GCC High against an enclave, or trying to get a straight answer out of an MSP's access model, start that conversation here before the contract is signed rather than after the assessment finds the gap. ◆